

Chapter-8

**Given a scenario, analyse
indicators of malicious activity**

Introduction

- Threats, Vulnerabilities, and Mitigations, is covered in this chapter.
- This chapter will look at signs of harmful behavior as well as the various kinds of malware and attacks that we can come across every day.
- In order to protect your environment and make sure you are ready to pass all of the exam questions pertaining to these ideas for your certification.
- This chapter will assist you in analyzing signs of malicious activity.

Malware (malicious Software) Attacks

- Malware is software designed to disrupt, damage, or gain unauthorized access to computer systems, networks, or devices.
- It can take various forms like viruses, worms, trojans, spyware, adware, and ransomware.
- They all share the common objective of causing harm to or compromising the targeted system or data.

Common types of malware attacks, methods, goals, and prevention techniques are discussed.

- Potentially Unwanted Programs (PUPs)
- Ransomware
- Trojans
- Remote Access Trojans
- Worms
- Spyware
- Bloatware
- Viruses
- Polymorphic Viruses
- Key loggers
- Logic Bombs
- Rootkits
- Malware Inspection

Potentially Unwanted Programs (PUPs)

- Potentially Unwanted Programs (PUPs) are downloaded inside other programs that consume computer resources and slow down.
- PUPs are seen as **grayware** as they are neither malicious nor legitimate.
- **Malwarebytes** alerts users of PUPs and allows to delete them.

Ransomware

- Ransomware **encrypts private files and demands payment in cryptocurrency** for their safe release.
- It can infiltrate computers via emails or malicious websites.
- Victims are left with a choice: comply with the ransom note or risk losing vital information.
- An example is the **Federal Bureau of Investigation (FBI) virus**, which impersonates a government agency and demands payment in the form of prepaid cards or cryptocurrency.

Trojans

- **Trojans are deceptive software that can trick users into downloading or executing malicious programs.**
- They can be embedded in web pages through code injection and can perform various malicious actions, including setting up backdoor access, surveillance, or resource theft.
- Trojans can also use Portable Executable (PE) files, which require user permission via a User Account Control (UAC) window and can be embedded inside legitimate software or packages.

Remote Access Trojans

- Remote Access Trojans (RATs) are stealthy infiltrators in the cyber realm, akin to modern Trojan horses.
- These hidden invaders are embedded within legitimate files, allowing cyber criminals remote control over compromised systems.
- This gives the RAT command and control of the computer; this means it can access the computer at any time and run a range of malicious activities, such as data theft or malware installation—all from a safe distance.

Worms

- A “worm” is malware that self-propagates and can reside in a computer’s memory.
- Unlike other forms of malware, worms possess an inherent ability to independently replicate and spread, reminiscent of biological organisms multiplying in their environment.
- Once a worm infiltrates a vulnerable system, it creates copies of itself and exploits security vulnerabilities to journey through interconnected networks, consuming network bandwidth as it rapidly infects new hosts.
- An example of a worm is the **NIMDA** (admin spelled backward) worm that emerged in September 2001. When NIMDA accessed a computer, it renamed all of the files with an .eml extension and, when the system was fully infected, an envelope appeared on the screen. Its target was Microsoft Internet Information Services (IIS), which is a web server. It also consumed a lot of network bandwidth and was difficult to eradicate.

Spyware

- Spyware is known for its **ability to slow down computers**, using a computer's processing power and RAM resources to covertly track user activities by using tracking cookies, before sending this collected information to third parties.
- Much like a skilled spy, spyware operates discreetly to gather data.
- Additionally, it's worth noting that while some tracking cookies are harmless, others can raise privacy concerns as they may collect personal information, such as usernames, email addresses, and even sensitive data such as credit card numbers, without proper consent or security measures. It can be a serious privacy violation.

Bloatware

- Bloatware **disguises itself as a helpful addition** to new devices.
- Drains performance and storage, sapping resources and slowing operations.
- This impacts user experience but isn't necessarily malware.
- The identification and removal of the bloatware is vital to counter this.

Viruses

- Viruses operate with various intentions;
 - aim to steal sensitive data,
 - others to disrupt systems,
 - to propagate further malware.
 - exploit vulnerabilities in the computer systems or software, often taking advantage of user behavior such as opening emails, downloading unverified files, or clicking on malicious links.
- Viruses can be resident in your computer's boot sector, in memory, or piggy-back on another program and run in its memory (this is called a **fileless virus**).
- To counteract viruses, individuals and organizations must employ a multi-layered approach to cybersecurity that includes the use of reputable antivirus software, up-to-date operating systems and software, and the practice of cautious online browsing.

Polymorphic Viruses

- Polymorphic viruses employ sophisticated techniques to modify their code, making them appear unique with each infection.
- This renders signature-based detection methods less effective, as the virus continually evolves to outsmart security measures.

Key loggers

- Keyloggers are **silent digital observers** that discreetly record keystrokes as users type on their keyboards, capturing sensitive information including passwords and credit card details.
- Often hidden in malicious software, they pose a threat to privacy and security, underscoring the importance of vigilant cybersecurity practices.

Logic Bombs

- Logic bombs are **digital time bombs** lying dormant within systems that are designed to trigger specific actions or disruptions at a predetermined time or condition.
- Triggers can be things such as a certain time, a script, a scheduled task, or logging in to a computer system.
- Logic bombs can delete files and corrupt data, often aiming to exact revenge, extort money, or compromise security.

Rootkits

- Rootkits hide their presence by burying themselves deep within operating systems, thus evading detection.
- Rootkits possess system-level access (akin to root-level or kernel-level access), which enables them to intercept system-level function calls, events, or messages through hooked processes and thereby exert control over a system's behavior.
- They grant cybercriminals remote control over compromised devices, allowing surreptitious access, data theft, and further malware deployment.
- These stealthy adversaries undermine trust and security, highlighting the importance of thorough security audits, advanced detection tools, and robust defenses to protect against them.

Malware Inspection

- When cyber security teams investigate potential malware or viruses, they need to use a sandbox.
- A **sandbox** is an isolated virtual machine, but specific sandboxing tools can also be used, such as **Cuckoo, a well-known open source sandbox**.
- The result is that, though the application is malicious, it does not affect network users.
- **Three reasons to sandbox an application are for patching, testing, and if the application is dangerous.**

Network Attacks

- A network attack is an unauthorized and malicious attempt to disrupt, compromise, or gain access to computer systems, data, or communication within a network, often for malicious purposes.
- Network attacks target organizations and households alike.
- Most of these attacks are called server-side attacks as they target an organization's servers, such as domain controllers, which hold user accounts, or SQL database servers, which hold confidential customer data and credit card information.
- The following sections will investigate several types of network attacks.
 - Pivoting
 - **Distributed Denial-of-Service (DDoS)**
 - ARP Poisoning
 - **Domain Name System (DNS) attacks**

Distributed Denial-of-Service (DDoS)

- A Denial-of-Service (DoS) attack is a type where one host prevents a victim's services from functioning.
- Distributed Denial-of-Service (DDoS) attacks involve multiple hosts attacking a victim's services by placing malware on computers or devices.
- **Botnets**, consisting of computers or IoT gadgets, team up to attack a victim's system, sending massive data to overwhelm it. This can be achieved through **SYN flood attacks**, which consume resources and hinder legitimate requests.
- DDoS attacks target system weaknesses, targeting financial extortion, hacktivism, and geopolitical power plays.
- Defending against them requires network enhancements, traffic filtering, and adaptive response mechanisms.
- Two of the most challenging attacks involve **amplifying** or **reflecting** traffic onto the victim.

Distributed Denial-of-Service (DDoS)

- **Amplifying attacks:**
 - Network-amplified attacks exploit the principle of sending a small request to trigger a larger response, leading to the amplification of traffic directed at the victim.
 - Attackers exploit protocols like the **Internet Control Message Protocol (ICMP)** to overwhelm targets with massive traffic volumes.
 - An example is the **Smurf attack**, where attackers send ICMP echo requests to an intermediary network device, causing the victim's system to be overwhelmed with an amplified volume of traffic, causing a DoS.
- **Reflected attacks:**
 - involve attackers obtaining a victim's IP address and creating a packet that is sent to servers, causing a flood of traffic that overwhelms the victim's server.
 - This can be seen in smart cities with interconnected devices like streetlights, where skilled attackers can manipulate DNS protocols to craft queries, crippling operations and underscoring the need for comprehensive defense strategies.

Domain Name System (DNS) attacks

- DNS is the backbone of the internet, responsible for translating hostnames or domain names
- Example: www.packtpub.com, into the numerical IP addresses that computers understand.
- It acts as a global directory that ensures users reach their intended online destinations seamlessly.
- However, this integral system is not impervious to exploitation.
- When a user types a website URL into their web browser, it uses DNS resolution to find the IP address of the website, but this process can be susceptible to attacks.

Domain Name System (DNS) attacks

- The key concepts related to DNS and attacks on the system are as follows:
- **DNS name resolution:** When someone types in the URL of a website, for example, www.packt.com, the DNS server uses DNS resolution to convert the www.packt.com URL hostname into its IP address.
- The name resolution process occurs in the following order:
 1. **DNS cache:** The system first checks the DNS cache. This is stored on the local machine. To view the cache, you can type `ipconfig /displaydns` into the command prompt. Because the DNS cache is the first place visited for DNS resolution, it is a prime target for attackers.
 2. **HOSTS file:** If the URL is not in the DNS cache, the system then checks the HOSTS file. This is a text file on the local computer. It is located on Windows computers under `C:\Windows\System32\drivers\etc`.
 3. **Root hints:** If the URL is not in the cache or the HOSTS file, the system then consults the root hints, which most often forwards the resolution to other DNS servers on the internet
- **DNS sinkhole:** A DNS sinkhole identifies known malicious domains and ingeniously sends back false information to potential attackers, preventing them from launching an attack. Or, the sinkhole might redirect the malicious actors to a honeypot instead for further analysis.
- **DNS cache poisoning: (aka DNS spoofing)** occurs when an attacker manipulates DNS records to redirect users to malicious websites. By poisoning the DNS cache with fake information, the attacker tricks users into believing they are visiting legitimate sites, all the while exposing them to fraudulent activities.
 - In the DNS resolution process, the DNS cache is searched for the name of the website, but the attackers have poisoned the cache with fake entries to redirect the victim to a fake website that looks like the legitimate website being sought. The attackers could also place fake information in the HOSTS file, which is the second place searched during the DNS resolution process.

On Path Attacks

- **On-path attacks**, also known as "man-in-the-middle" or interception attacks, involve adversaries intercepting communication between parties, allowing cybercriminals to exploit sensitive information, launch attacks, or manipulate transactions undetected, including rogue access points and evil twins.
- Other types of on-path attacks are:
 - **Session Replay** When a user connects to a web server, a session token is created (this may be saved as a cookie). In a session-hijacking attack, the attacker intercepts the token using Cross-Site Scripting (XSS), man-in-the-browser, or man-in-the-middle attacks.
 - A **replay attack** intercepts data and replays it at a later date. Kerberos prevents this by assigning unique sequence numbers and timestamps to each authentication request and response. For example, in Windows networks, data transmitted with different sequence numbers prevents replay attacks.

Credential Replay

- Among the most prevalent and damaging cyberattacks are credential replay attacks, which involve malicious code, keyloggers, packet sniffers such as Wireshark or tcpdump, or credential-capturing malware.
- Two main types of credential attacks are as follows:
 - **Credential replay attacks** involve attackers capturing valid credentials during a legitimate login attempt and using them to gain unauthorized access. Administrators should avoid Telnet for remote access due to its non-encrypted credentials. Secure Shell (SSH) is recommended for secure remote administration. The legacy NT LAN Manager (NTLM) authentication protocol should be discouraged.
 - **Credential stuffing** is an attack where attackers use the same credentials for all accounts, compromising all matched accounts. Organizations should monitor login spikes and failed attempts. To prevent this, companies should conduct security awareness training, encourage unique passwords, and use password managers.

Malicious Code

- Malicious code is a dark aspect of software development, aiming to infiltrate systems, steal data, and cause digital chaos.
- Early indicators include unusual network traffic patterns, unexpected system behaviour, and unfamiliar files or software.
- Detecting anomalies and monitoring for unusual behaviour enhances cyber security.
- Examples of malicious code attacks include the following:
 - Bash shell attacks
 - Python
 - Java Script
 - XSS

- **Bash Shell Attack:** The Bash shell, a powerful tool in Unix-like operating systems, can be exploited for malicious purposes, including unauthorized command execution, system compromise, and file manipulation. (Example of bad script, see from book)
- **Python**, a simple and versatile programming language, has gained popularity among cybercriminals due to its ability to execute various actions, including keylogging and data exfiltration, through phishing emails. (Example of bad script, see from book)
- **JavaScript**, a crucial component of web development, is frequently exploited by attackers for client-side attacks, allowing malicious code to steal user data, redirect traffic, and execute unauthorized transactions. (Example of bad script, see from book)

Indicators of Attack

- Indicators of Attack (IoAs) provide early warnings of potential threats by identifying suspicious activities or behaviors within a network, thereby helping organizations proactively defend against cyberattacks.
- The following are some common indicators that will help you identify attacks:
 - **Account lockouts**, particularly for privileged accounts, are a **warning sign** of potential malicious attempts to gain unauthorized access, often triggered by brute-force attacks.
 - **Concurrent session usage: Monitoring** the number of concurrent user sessions can reveal suspicious activity. Sudden spikes or a significantly higher number of concurrent sessions than usual might indicate unauthorized access or a breach in progress.
 - **Blocked content** indicators reveal attempts to access valuable data, such as ACLs and DLP systems, which log access denied messages and events if auditing is configured.
 - **Impossible travel** refers to multiple logins from distant locations in an unrealistically short timeframe, potentially indicating account compromise by an attacker.
 - **Resource consumption:** Unusual spikes in resource consumption, such as excessive CPU or memory usage, might suggest a malware infection or a DDoS attack targeting your systems.
 - **Resource inaccessibility:** When critical resources become suddenly inaccessible, it could be a sign of a cyberattack, either due to network issues or a deliberate effort to disrupt services. An example of this is a DDoS attack.
 - **Out-of-cycle logging:** Logs that are generated at unusual or unexpected times can be indicative of suspicious activities. Cyber attackers often manipulate logs to cover their tracks, so irregular log generation times warrant investigation.
 - **Published/documented:** Published or documented vulnerabilities and configuration settings can attract malicious actors. Regularly checking your organization's systems against such known issues can help prevent attacks.
 - **Missing logs:** The absence of expected logs (especially during critical events or incidents) can be a clear sign of tampering or an attempt to hide malicious activities.